Network-Based Forensic Reconstruction of IoT Device Behaviour

Master in Cybersecurity Engineering |

Computer Forensics & Cyber Crime Analysis

Eric Ruiz Giménez

Table of Contents

IoT Device

- **Physical object** embedded with sensors, software and networking technology that allows it to autonomously connect and exchange data with other devices and centralized cloud systems.
- Act as the **Edge** between the digital and physical worlds
- **Operate autonomously** but with **constrained resources**
- Networked communications by the use of **low-power network stacks to support device-to-device communication or device-to-cloud communications**

IoT Challenges

- According to the **OWASP** the IoT ecosystem have several critical security challenges:
- **Weak, Guessable or Hardcoded Passwords**
- **Insecure Network Services**
- **Lack of Secure Update Mechanisms**
- **Insecure Data Transfer and Storage**

IoT Forensic Crisis

- **Inadequacy of Traditional Methods:** "Dead-box" analysis fails due to proprietary hardware and lack of standard interfaces (SATA/USB).
- **Data Volatility:** Evidence is stored in volatile RAM. Reboots or power cycles result in permanent data destruction.
- **Encryption Barrier:** Pervasive use of encrypted payloads makes Deep Packet Inspection (DPI) obsolete for modern investigators.
- **Semantic Gap:** Disconnection between raw network packets and physical device actions.
- **Time Synchronization:** Multiple sources presents the possibility of different timestamp interpretations and clock drift issues.
- **Volume and Background Noise:** Constantly generate background traffic such as Keep-Alive messages, NTP synchronizations

Objectives

- Can an IoT device activity be inferred solely from network traffic?
- Which network features best identify device behaviours?
- How accurately can forensic timelines be reconstructed?

The Encrypted Payload Barrier

MQTT Over TLS

Standard for smart homes. Payload can be encrypted, so investigators must rely on Port 8883 metadata and "Keep-Alive" rhythms.

CoAP & DTLS

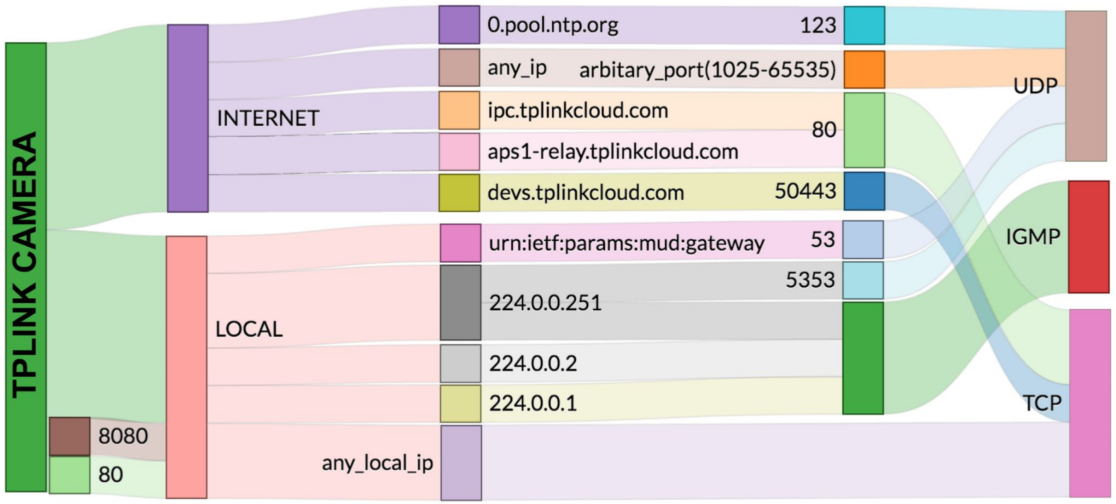
Lightweight RESTful alternative over UDP (5684). Connectionless nature requires temporal clustering to infer device interaction.

HTTP/S Metadata

Identifying devices via Server Name Indication (SNI) and cryptographic fingerprints during the initial TLS handshake.

*The investigation shifts from **Content-based** to **Context-based** analysis.*

Behavioral Ground Truth: NIST 8259 - MUD



Manufacturer Usage Description (NIST SP 1800-15)

- Defines authorized network access control entries (ACEs).
- Establishes a **predictable network footprint** for specific devices.
- Any deviation acts as a "High-Fidelity" trigger for forensic events.
- Allows mapping packet sequences to physical triggers (Sensor → Aggregator → Decision).

Simulated Environment & Topology

Infrastructure

Mininet Orchestration

Virtual smart home with Open vSwitch (OVS) Gateway.

Smart Camera

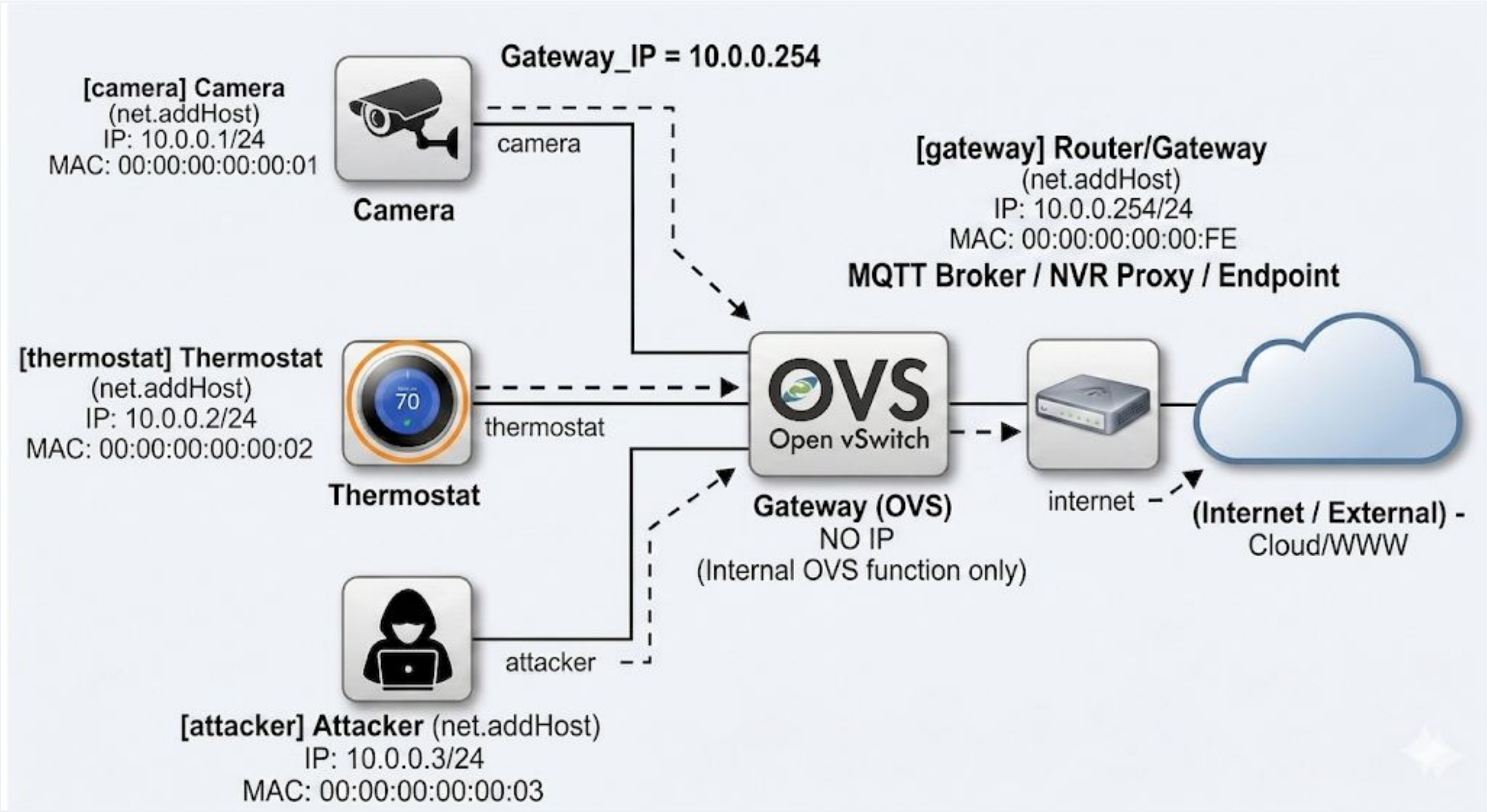
High-bandwidth node (UDP 50005) for streaming and cloud telemetry.

Smart Thermostat

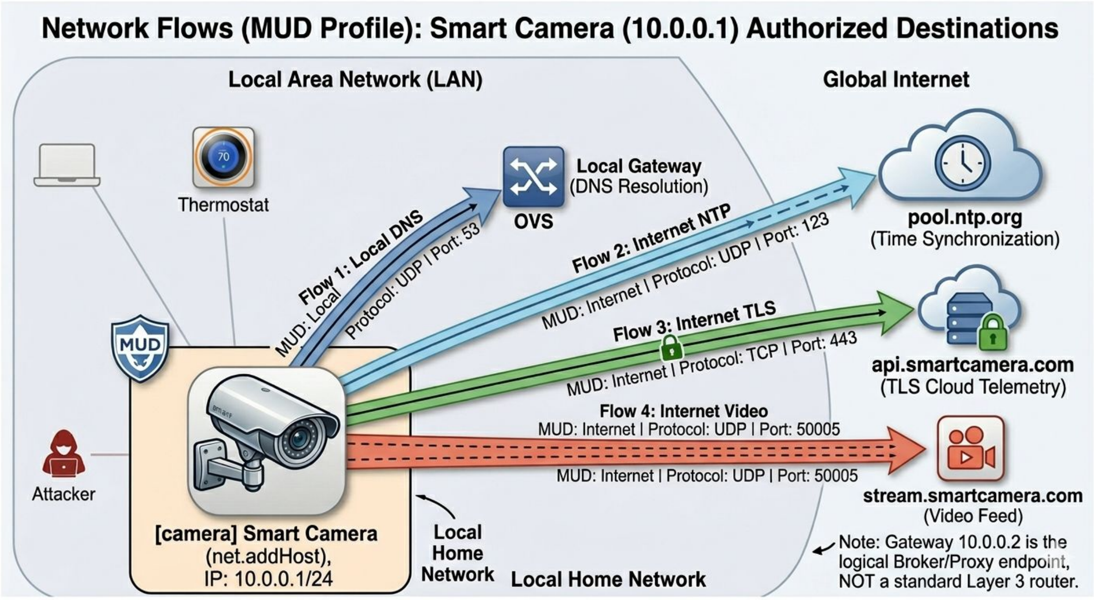
Low-bandwidth node (MQTT 8883) for periodic environmental updates.

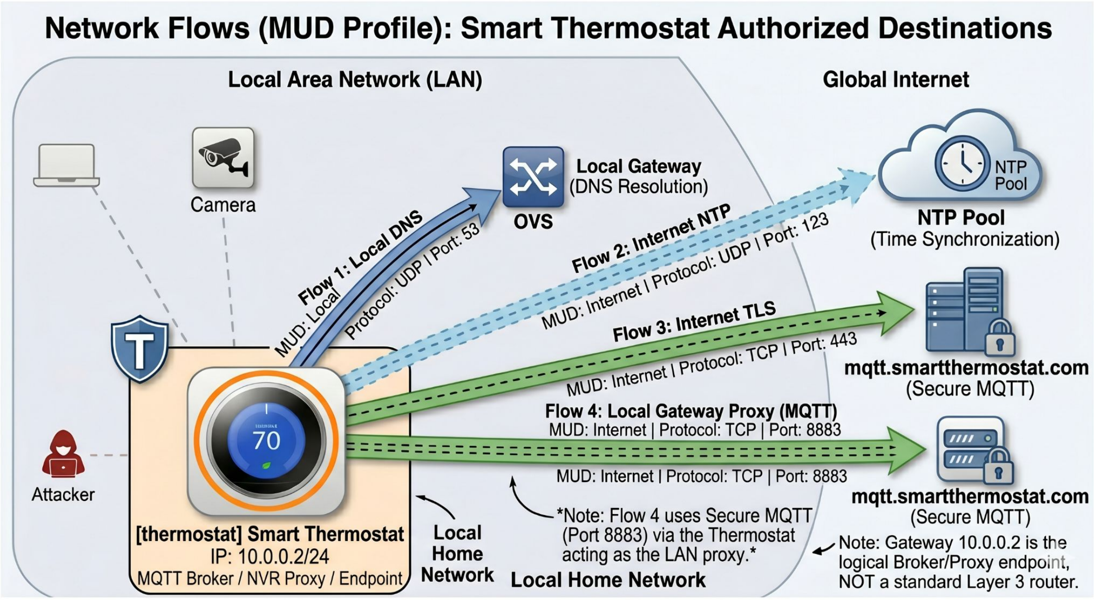
Attacker Node

Internal asset (10.0.0.3) used for lateral movement and reconnaissance.



MUD Profiles





Behavioral and State Fingerprinting

Device Identification

Focuses on static hardware profiling. Analyzes DNS initialization patterns, handshakes, and SNI extensions to determine device make, model, and embedded OS.

Behavioral Fingerprinting

Passively observes statistical metadata to infer active physical states. Maps variations in traffic flows to specific triggers like motion detection, reboots, or exfiltration.

Behavioral and State Fingerprinting

- Packet Length Distributions
- Inter-Arrival Time (IAT)
- Flow Volume / Duration / Destination
- Protocol Behaviour

Comparative Device Baselines

Metric Type	Smart Camera (Baseline)	Smart Thermostat (Baseline)
Inter-Arrival Time	Volumetric (Streaming)	10.00s (Rigid Pulse)
Typical Packet Size	Variable (Bitrate dependent)	Deterministic (27 Bytes)
Protocol Behavior	High-Density UDP Stream	Periodic TCP Keep-Alives
Flow Destination	Port 50005 (Video Gateway)	Port 8883 (MQTT Broker)

Scenarios

- Scenario 1: Operational Baseline (Ground Truth)
- Scenario 2: Network Reconnaissance & Brute-Force
- Scenario 3: State Change & Data Exfiltration
- Scenario 4: Botnet Infection

The 4-Phase Forensic Pipeline

1

Collection

SHA-256 Hashing of PCAP files to ensure chain of custody.

2

Examination

Zeek logs extraction (conn.log, dns.log) bypassing DPI.

3

Normalization

Filtering environment noise and calculating Inter-Arrival Times (IAT).

4

Analysis

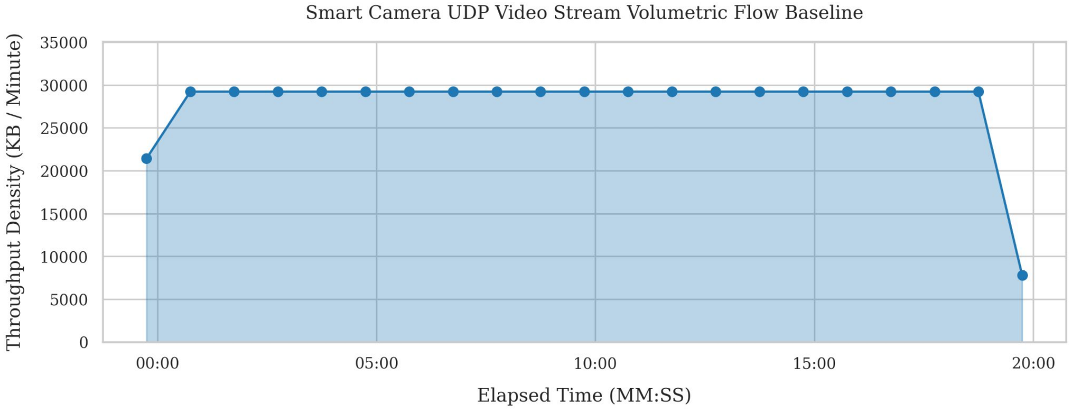
Behavioral reconstruction against the Ground Truth baseline.

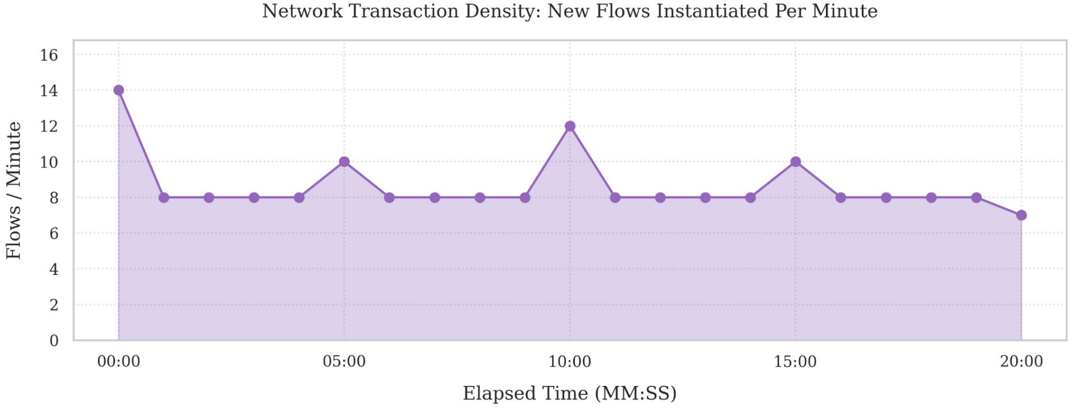
Operational Baseline Ground Truth

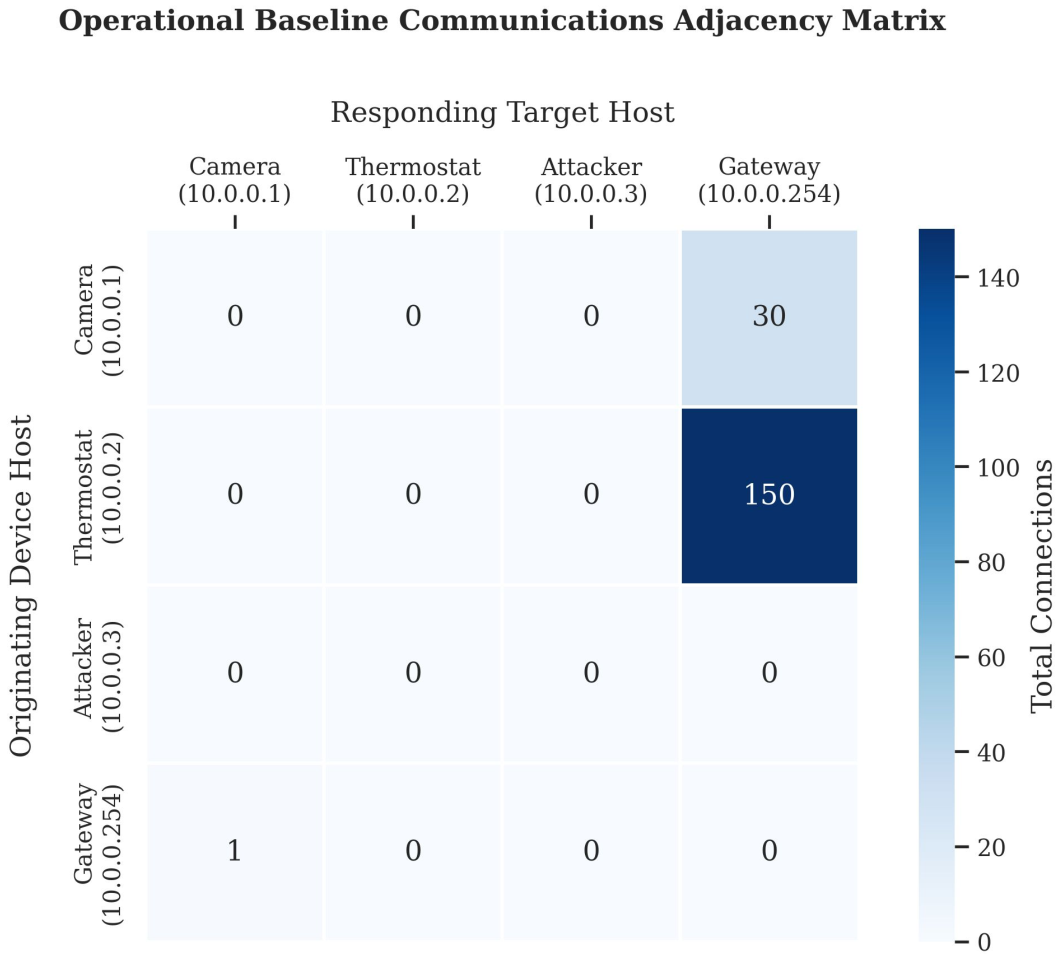
Traffic Classification	Expected Flows	Empirical Flows	Status
DNS Queries (UDP/53)	42	42	✓Correct
MQTT Keep-Alives (TCP/8883)	121	121	✓Correct
NTP Sync (UDP/123)	6	6	✓Correct
Video Stream (UDP/50005)	1	1	✓Correct

$$IAT = t_n - t_{n-1} \approx 10.0s$$

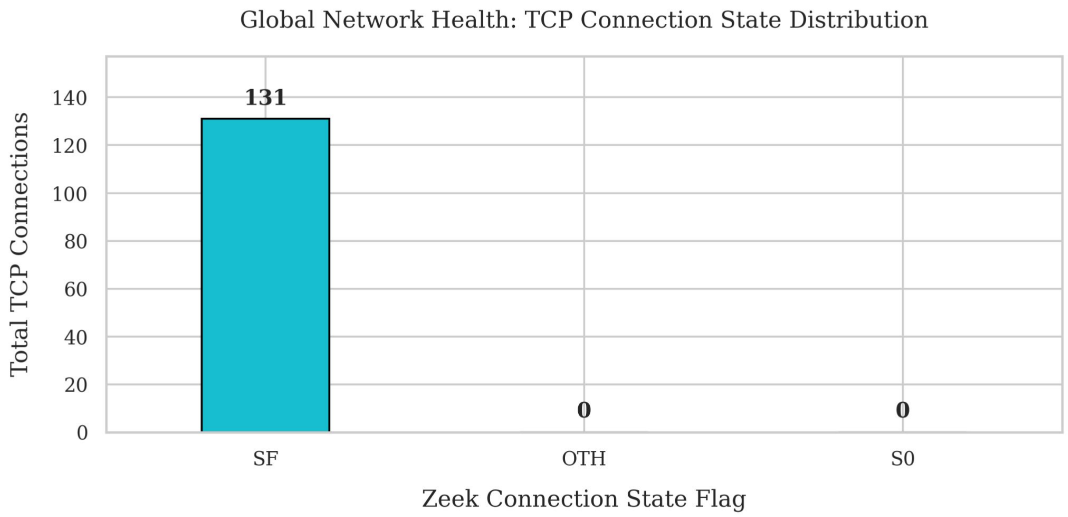
Operational Baseline Ground Truth

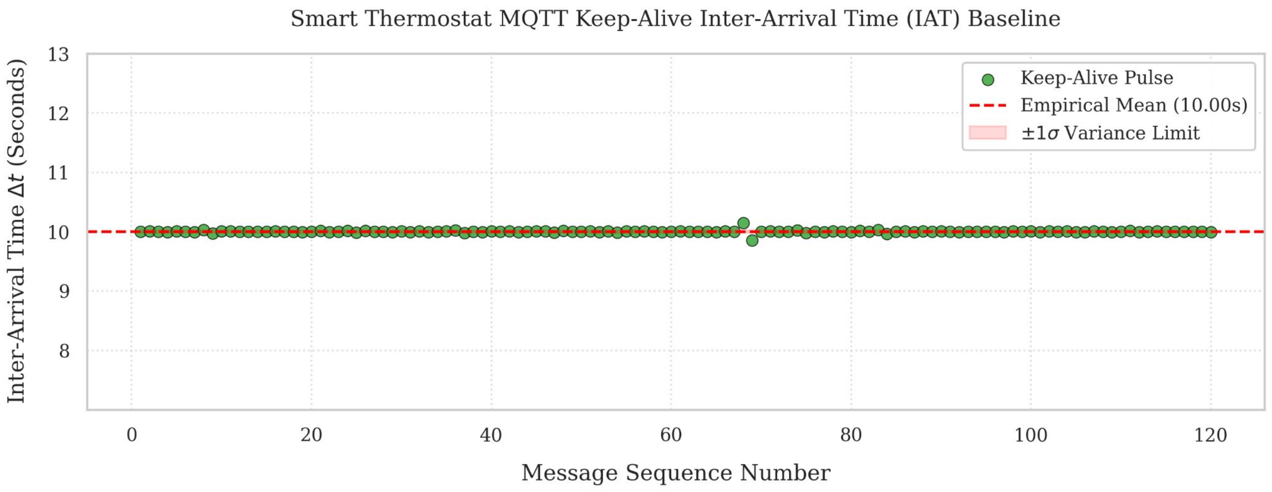






Operational Baseline Ground Truth



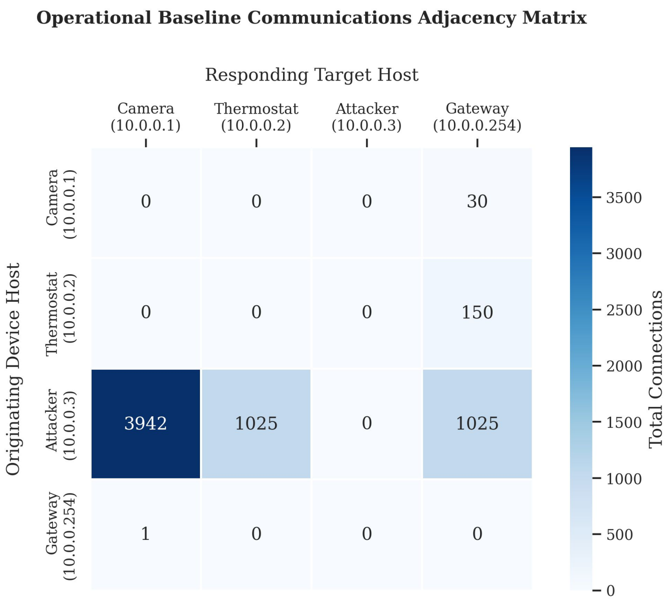


Reconnaissance & Brute-Force

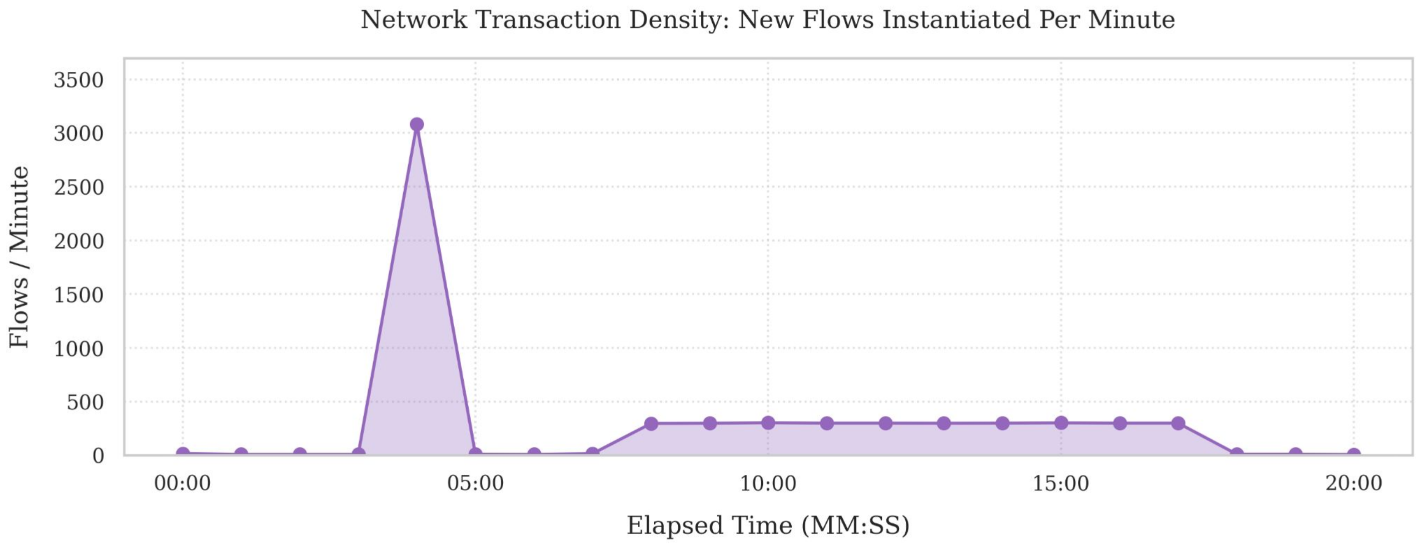
Forensic Signature:

A **3,329% volumetric spike** in the expected number of flows (180 vs 5592). 3,074 caused by the Network Reconnaissance and 2,918 by the Credential Brute Force.

Adjacency Matrix



Flow Timeline

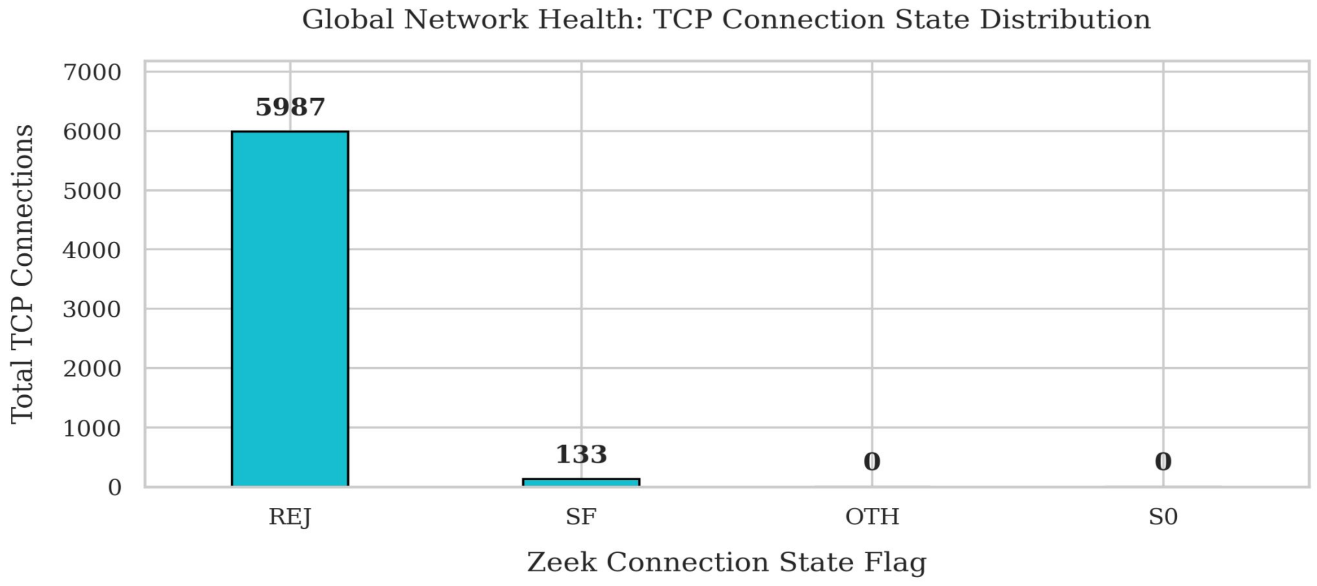


Reconnaissance & Brute-Force

Forensic Signature:

A total of **5987** rejected connections by the network devices highlight the existence of a possible Brute Force Attack.

Connection Distribution



Exfiltration & Port Masquerading

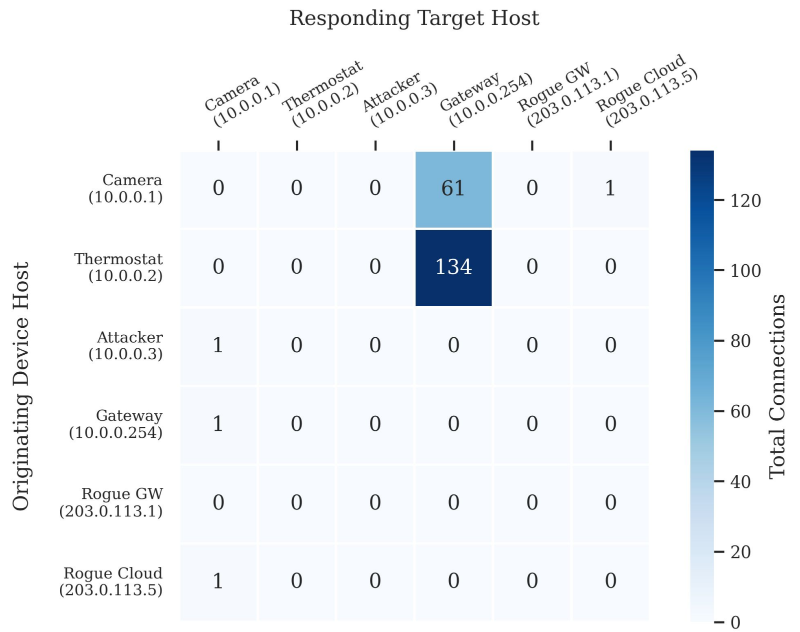
Forensic Insights:

Stealthy Pivot: Compromised camera redirects feed to Rogue Cloud (203.0.113.5).

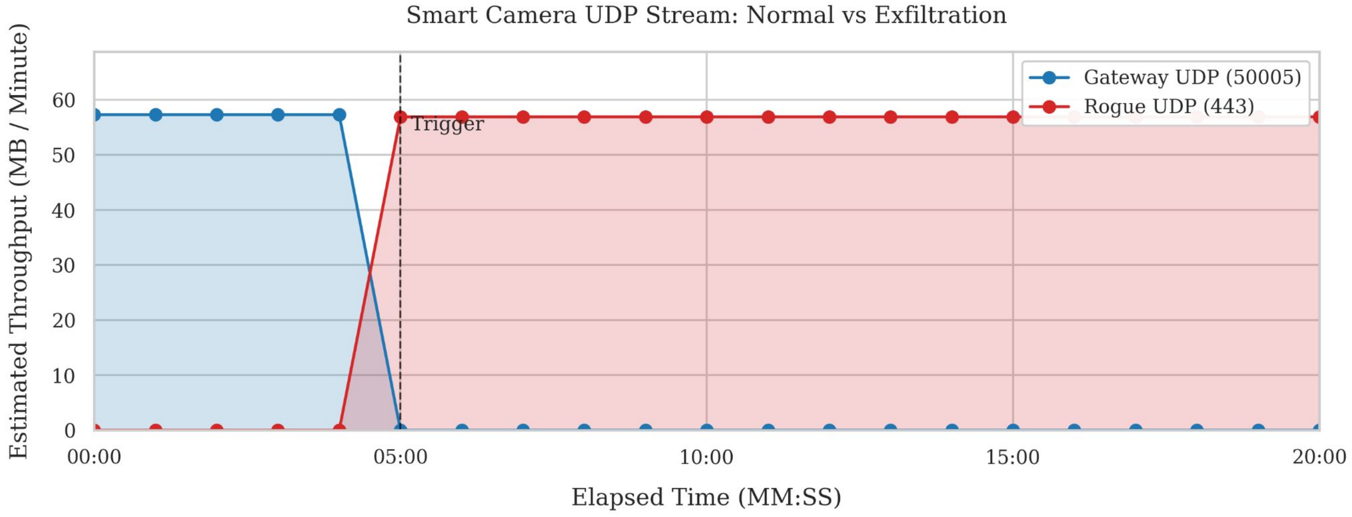
Evasion: Use of UDP Port 443 to masquerade as benign HTTPS. Extra 16 DNS queries to C2 domain.

Volumetric Camouflage: Total throughput remained constant. The anomaly can only be detected via **topological shift** in adjacency matrix.

Adjacency Matrix



UDP Traffic Flow Timeline



Botnet Infection & Lateral Movement

Infection Event

Thermostat infected via targeted payload at t=300s .

Lateral Propagation

128 anomalous flows targeting ports 23/80 on adjacent IoT assets.

C2 Link

Persistent IRC control channel established on Port 6667.

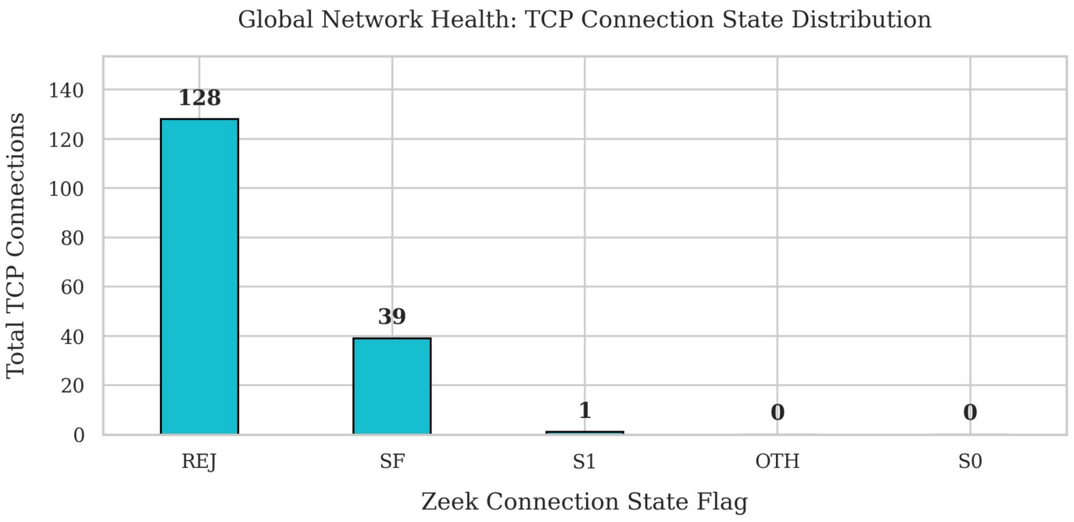
Catastrophic Zero-Trust Breach: Trusted edge devices repurposed as offensive launchpads.

Botnet Infection & Lateral Movement

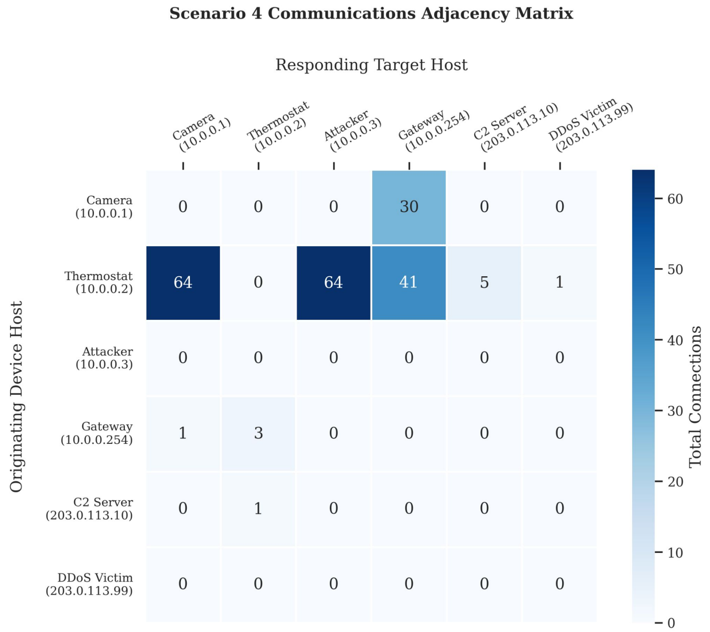
Forensic Insights:

Infection Vector: Thermostat targeted by the attacker sending a malicious payload.
Propagation: Rapid horizontal scanning of local subnet (192.168.1.0/24) over Telnet (23) and HTTP (80).
Botnet Behaviour:

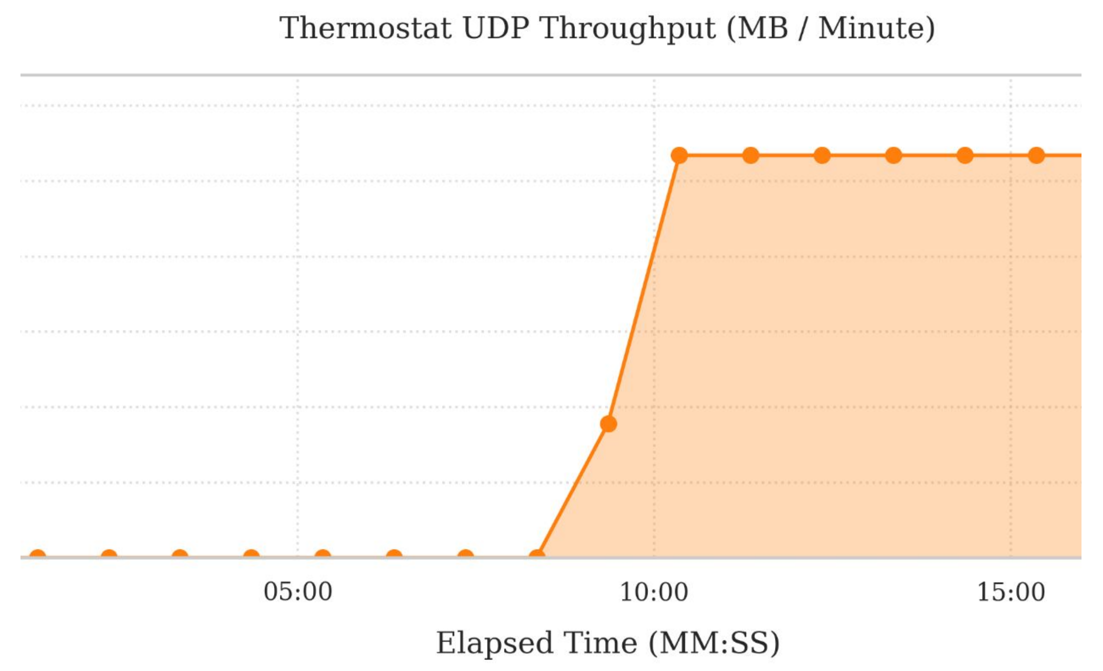
TCP Connection State Distribution

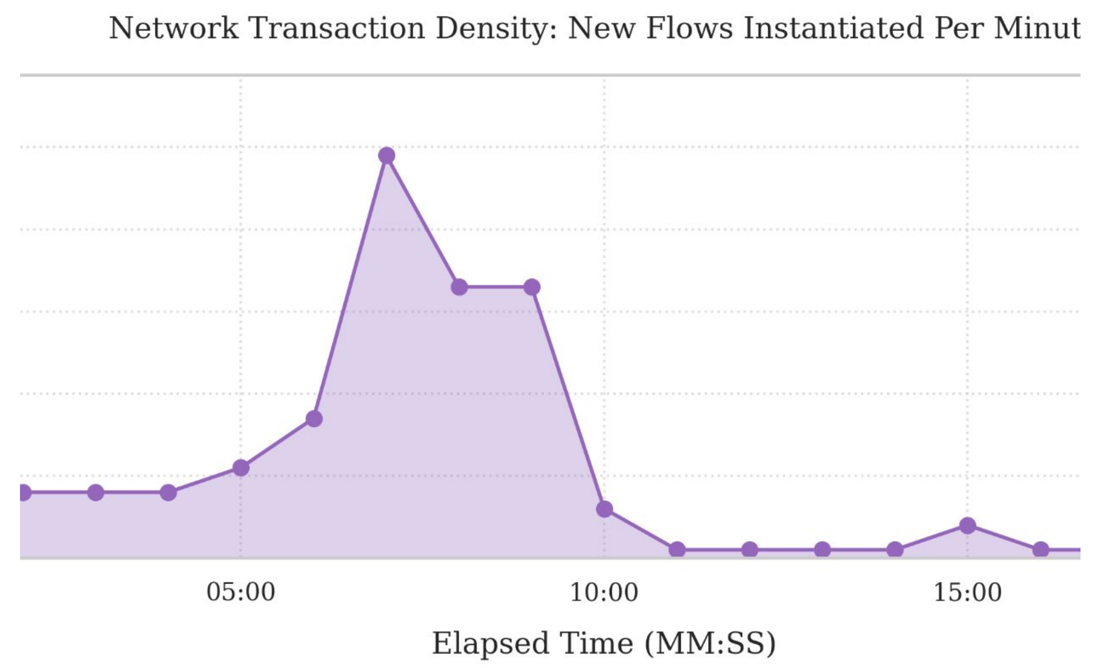


Heatmap: Connection Density Over Time



Botnet Infection & Lateral Movement





Live Demonstration

Passive Metadata Extraction in Action

Demonstrating the transition from raw PCAP to Zeek-extracted behavioral fingerprints for adapted Scenario 4.

Conclusion

Physical IoT state changes can be reliably reconstructed strictly from encrypted network metadata, bridging the forensic semantic gap.

Thank you for your attention.